

Escuela de Ingeniería
Ingeniería Civil en Computación

Evaluación de la seguridad de software y arquitectura de la plataforma Maria.ag y propuesta de medidas de mitigación

Felipe Sebastián Suárez González

Profesor guía: Edgardo Ortiz

Memoria para optar al título de ingeniero civil en computación

Rancagua, Chile
2026

Declaración de uso de Inteligencia Artificial

En la elaboración de este trabajo de título se utilizó Claude, desarrollado por Anthropic, como apoyo en las siguientes tareas: reestructuración y reorganización de los capítulos del documento en LaTeX, integración de los diagramas de arquitectura (modelo C4) en el informe, revisión de la coherencia entre las secciones del texto, y apoyo en la redacción de la hipótesis, las preguntas de investigación, los objetivos y el capítulo de Metodología. Su uso se concentró específicamente en la estructura general del documento, el Marco teórico, las Figuras de contexto y de contenedores, y los capítulos de planteamiento del problema y Metodología.

Todo el contenido generado o asistido por inteligencia artificial fue revisado, verificado y validado por el autor, quien asume la responsabilidad íntegra sobre la exactitud, originalidad y pertinencia del contenido final presentado en este documento.

Índice

Resumen **3**

Introducción **4**

Marco teórico **6**

Seguridad de la información y de las aplicaciones web 6

Arquitectura de referencia de Maria.ag (modelo C4) 6

Metodologías y estándares de referencia 7

Control de acceso en arquitecturas multiusuario 10

Seguridad de interfaces de programación de aplicaciones (API) 11

Seguridad en sistemas con componentes ciberfísicos 11

Hipótesis **13**

Preguntas de investigación **14**

Objetivo general **15**

Objetivos específicos **16**

Metodología **17**

Enfoque general 17

Alcance 17

Autorización, entorno de pruebas y consideraciones éticas 18

Fases del trabajo 18

Herramientas 20

Clasificación de hallazgos 20

Criterios de priorización 20

Evaluación del plan de mitigación 21

Limitaciones 22

Referencias **23**

Resumen

Este trabajo evalúa la seguridad del software y de la arquitectura de la plataforma Maria.ag de la empresa Gota SpA, clasifica y prioriza los hallazgos identificados y propone medidas de mitigación para los de mayor riesgo, estimando la reducción de riesgo que lograrían, tomando como referencia la Guía de Pruebas de Seguridad Web de OWASP, el OWASP Top 10 y el sistema de puntuación CVSS.

Introducción

En este capítulo se presenta el contexto del trabajo realizado en esta memoria de título, la problemática que lo motiva, su justificación y los objetivos que se abordan.

Gota SpA es una empresa especializada en soluciones de riego avanzadas, cuyo objetivo es mejorar el uso del agua en la agricultura, reducir costos y aumentar la productividad de los cultivos [1]. Entre sus servicios cuenta con monitoreo de equipos de riego, instalación de equipos de telemetría y un software propio, Maria.ag, que utiliza un modelo de riego predictivo para regar de manera óptima, realiza un balance hídrico en tiempo real y entrega recomendaciones de cuándo y cuánto regar [1, 2].

Maria.ag es una aplicación web multiusuario: cada empresa cliente accede mediante cuentas con credenciales propias y datos de campo que le son exclusivos (suelos, sectores de riego, especies cultivadas), por lo que la plataforma debe garantizar un aislamiento efectivo entre los distintos clientes que comparten la misma infraestructura. Sobre la base de los datos ingresados por el usuario y de la información recibida mediante integraciones externas, el modelo predictivo genera recomendaciones de riego que el usuario puede aceptar o complementar registrando riegos de forma manual. Estas recomendaciones y registros no permanecen únicamente dentro de la aplicación: Maria.ag se comunica mediante API con plataformas de terceros –como Dropcontrol, Talgil y Galcon– a las que no solo consulta información meteorológica y de telemetría, sino a las que también envía instrucciones de riego para su ejecución. Esta última característica traslada una parte del riesgo de seguridad del plano exclusivamente digital al plano físico, ya que una falla en la validación de los datos que viajan hacia estas integraciones, o un acceso indebido a las credenciales que las habilitan, podría derivar en la activación incorrecta de equipos de riego en terreno.

Según lo informado por la empresa, durante el desarrollo de la plataforma se priorizó alcanzar una operatividad mínima, dejando en segundo plano aspectos como la documentación o la realización de pruebas rigurosas de seguridad. Esta situación expone a la plataforma a posibles vulnerabilidades cuyo impacto puede ir desde la filtración o alteración de información de los clientes –incluyendo el acceso de una empresa a los datos de otra– hasta la alteración del funcionamiento de la plataforma y, en el caso de las integraciones con capacidad de accionamiento, del propio proceso de riego en campo.

Frente a este escenario, este trabajo propone realizar una evaluación de seguridad de la arquitectura y del software de Maria.ag, con especial atención al aislamiento entre clientes, a la autenticación y gestión de sesiones, a la validación de los datos ingresados y

transmitidos, y a la seguridad de las integraciones con plataformas externas, seguida de la priorización de los hallazgos y de la propuesta de medidas de mitigación, cuya reducción de riesgo se estima y se valida con el equipo de desarrollo de la empresa. Para ello, se utilizará como referencia la Guía de Pruebas de Seguridad Web de OWASP [3], el OWASP Top 10 [4], el sistema de puntuación CVSS [5] y, dado el carácter de las integraciones externas de la plataforma, los lineamientos del OWASP API Security Top 10 [6].

El trabajo se justifica en la necesidad de proteger los datos de los clientes, la continuidad operativa de la aplicación, la integridad del proceso físico de riego que depende de ella y, según lo informado por la empresa, la ausencia de evaluaciones de seguridad previas en la empresa.

Tras el marco teórico, se presentan la hipótesis, las preguntas de investigación, el objetivo general, los objetivos específicos y la metodología.

Marco teórico

En este capítulo se presentan los conceptos, estándares y metodologías que sustentan la evaluación de seguridad desarrollada en este trabajo. Se abordan, en orden, los fundamentos de la seguridad de aplicaciones web, las metodologías y marcos de referencia utilizados para guiar la evaluación, los riesgos propios de arquitecturas multiusuario como la de Maria.ag, la seguridad de las interfaces de programación de aplicaciones (API) dado el rol central que estas cumplen en la plataforma, y las particularidades de seguridad que surgen cuando un sistema de software tiene capacidad de incidir sobre procesos físicos, como ocurre con el riego agrícola.

Seguridad de la información y de las aplicaciones web

La seguridad de la información se organiza tradicionalmente en torno a tres propiedades conocidas como la tríada CIA: *confidencialidad*, que garantiza que la información solo sea accesible para quienes están autorizados a conocerla; *integridad*, que asegura que los datos no sean alterados de forma no autorizada o accidental; y *disponibilidad*, que asegura que los sistemas y datos estén accesibles cuando se requieran [7]. Estas tres propiedades constituyen el criterio base para clasificar el impacto de cualquier vulnerabilidad identificada durante la evaluación.

En el caso particular de las aplicaciones web, la seguridad se ve condicionada por su arquitectura cliente-servidor y por la exposición pública de sus interfaces, lo que amplía la superficie de ataque respecto de aplicaciones de uso exclusivamente local. Los riesgos más comunes en este tipo de sistemas incluyen fallas en el control de acceso, en la validación de entradas, en la gestión de sesiones y en la configuración de los componentes que conforman la aplicación [4].

Arquitectura de referencia de Maria.ag (modelo C4)

Para situar la evaluación de seguridad en la arquitectura concreta de la plataforma, y no solo en generalidades sobre aplicaciones cliente-servidor, se emplea el modelo C4 [8], una notación que describe un sistema de software en niveles crecientes de detalle. Este trabajo utiliza sus dos primeros niveles: el diagrama de *contexto* (C1), que sitúa a Maria.ag frente a sus usuarios y a los sistemas externos con los que se relaciona, y el diagrama de *contenedores*

(C2), que muestra los grandes bloques de software –aplicaciones, servicios y almacenes de datos– que componen la plataforma y cómo se comunican entre sí.

Los diagramas que siguen se elaboraron a partir de la política de privacidad de Maria.ag y de la información recabada durante la pasantía; deben entenderse como una hipótesis de arquitectura a validar con el equipo de desarrollo de Gota SpA –en particular una vez que se obtenga acceso al repositorio– y no como una descripción certificada del sistema. Aun con esa salvedad, permiten delimitar la superficie de ataque de la plataforma y anticipar en qué componentes se concentrarán las pruebas de seguridad.

La Figura 1 presenta el diagrama de contexto (C1). En él se observa que Maria.ag es utilizada por dos tipos de actores –el personal de las empresas clientes y el personal de Gota SpA– y que se comunica con cinco sistemas externos: Agroclima, del que obtiene datos meteorológicos; Dropcontrol y Talgil, con los que intercambia telemetría y a los que además envía recomendaciones de riego para su ejecución; Galcon, al que envía recomendaciones de riego; y Hotjar/Microsoft Clarity, que recopila analítica de navegación sin que esos datos se almacenen en la base de datos de la plataforma. Las integraciones con capacidad de accionamiento –Dropcontrol, Talgil y Galcon– son, de acuerdo con lo discutido en la sección anterior, las de mayor relevancia para este trabajo, pues son las que trasladan un eventual error de software hacia el proceso físico de riego.

La Figura 2 hace un acercamiento (C2) al interior de Maria.ag y distingue cuatro contenedores: una *aplicación web*, con la que interactúa el usuario desde su navegador; una *API o backend*, que concentra la autenticación, el control de acceso y la orquestación de las integraciones externas; un *motor de recomendación*, que ejecuta el modelo predictivo de riego; y una *base de datos*, que almacena las cuentas, los datos de suelos y sectores, los registros de riego manual y la información recibida de las integraciones. Bajo esta hipótesis de arquitectura, la API/backend es el componente que concentra la mayor superficie de ataque, al ser el punto donde confluyen la autenticación de los usuarios, el control de acceso entre empresas clientes y la comunicación con los sistemas externos con capacidad de accionamiento.

Metodologías y estándares de referencia

OWASP Top 10

El *Open Worldwide Application Security Project* (OWASP) es una comunidad abierta dedicada a mejorar la seguridad del software. Su proyecto OWASP Top 10 [4] identifica y describe las diez categorías de riesgo más críticas en aplicaciones web, construidas a partir de datos aportados por organizaciones de seguridad a nivel mundial. Entre estas categorías

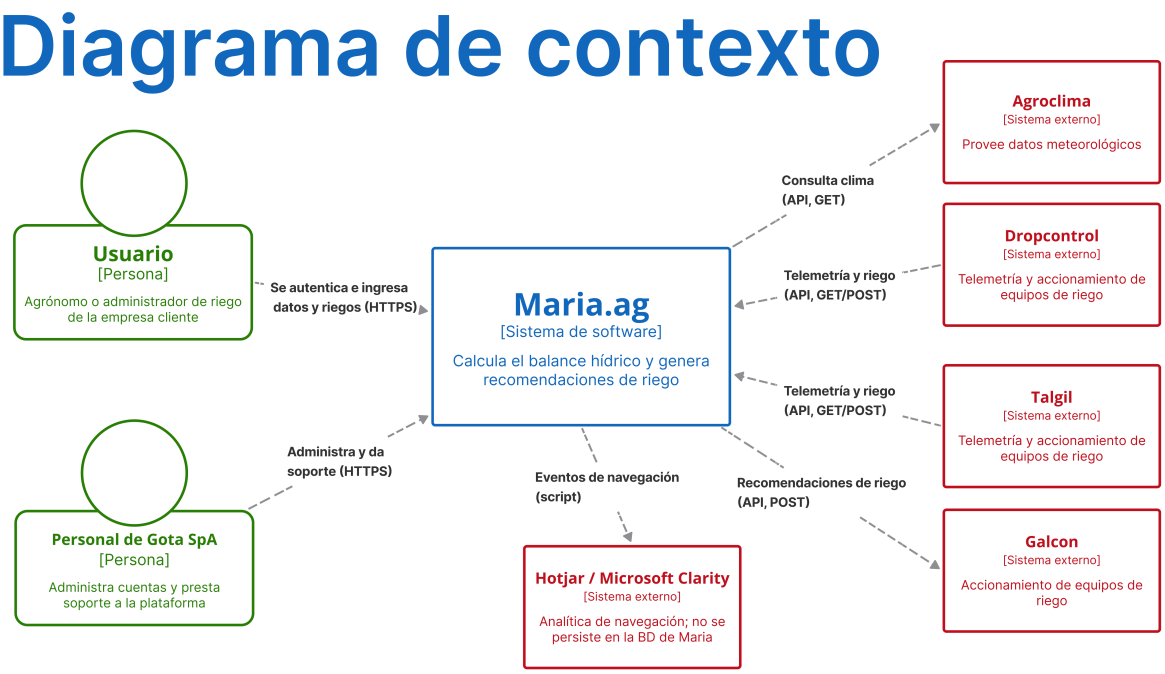


Figura 1: Diagrama de contexto (C1) de Maria.ag, elaborado a partir de la política de privacidad de la plataforma y de la información recabada durante la pasantía. Pendiente de validación con el equipo de desarrollo de Gota SpA.

se encuentran el control de acceso roto (*broken access control*), las fallas criptográficas, la inyección de código y las fallas de diseño relacionadas con la lógica de negocio de la aplicación. Este trabajo utiliza el OWASP Top 10 como taxonomía para clasificar los hallazgos identificados.

OWASP Web Security Testing Guide (WSTG)

La Guía de Pruebas de Seguridad Web de OWASP [3] es un marco metodológico que describe, de manera estructurada, los procedimientos para evaluar la seguridad de una aplicación web a lo largo de su ciclo de desarrollo. La guía organiza las pruebas en categorías –gestión de la configuración, autenticación, gestión de sesiones, validación de datos, lógica de negocio, entre otras– y, para cada una, define objetivos, técnicas y criterios de verificación. En este trabajo, la WSTG se utiliza como procedimiento operativo para ejecutar la evaluación de seguridad de Maria.ag.

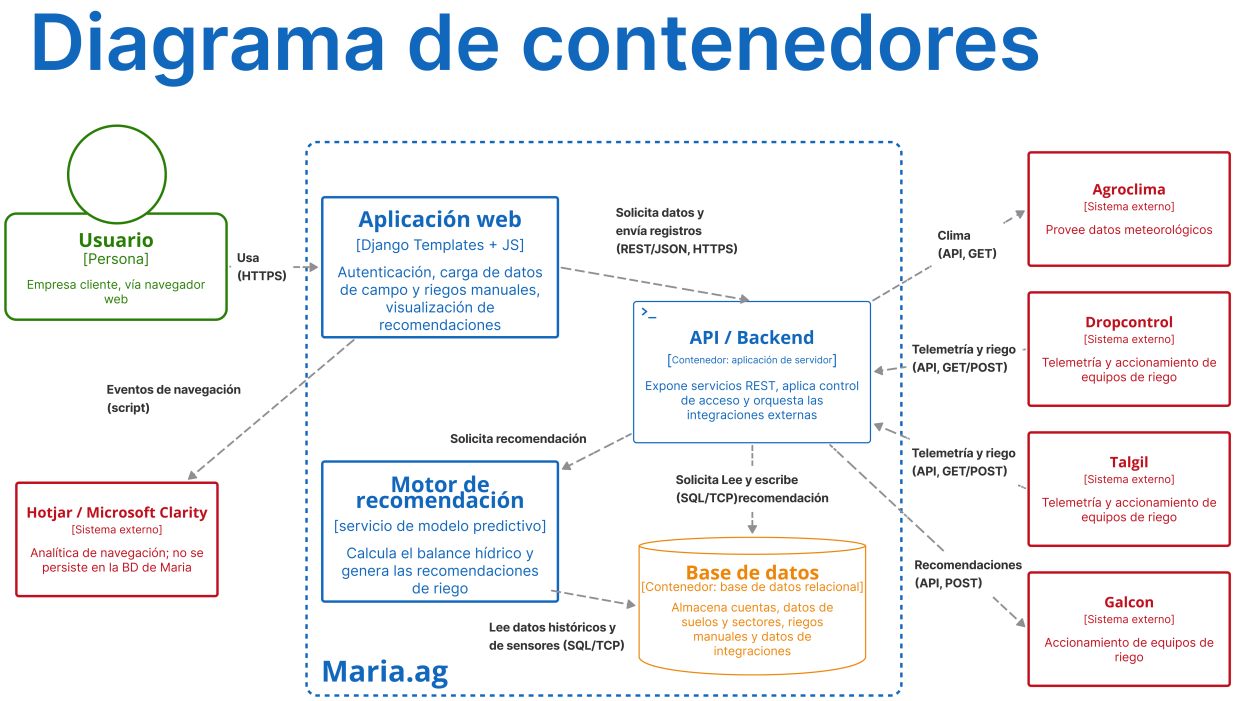


Figura 2: Diagrama de contenedores (C2) de Maria.ag: bloques principales de software y sus relaciones, bajo la misma hipótesis de arquitectura que la Figura 1.

Common Vulnerability Scoring System (CVSS)

El Common Vulnerability Scoring System [5] es un estándar abierto que permite asignar una puntuación numérica a la severidad de una vulnerabilidad, a partir de métricas base –como el vector de ataque, la complejidad de explotación y el impacto sobre la confidencialidad, integridad y disponibilidad– que pueden complementarse con métricas temporales y de entorno. La puntuación resultante, en una escala de 0 a 10, permite comparar y priorizar hallazgos de distinta naturaleza bajo un mismo criterio cuantitativo, lo que en este trabajo se utiliza tanto para priorizar las vulnerabilidades a mitigar como para comparar el estado de la plataforma y para estimar la reducción de riesgo que lograría la aplicación de las medidas propuestas.

Modelado de amenazas

El modelado de amenazas es un proceso estructurado para identificar, de forma anticipada, las posibles formas en que un sistema puede ser atacado, a partir de la descomposición de su arquitectura, la identificación de sus activos y puntos de confianza, y el análisis de los flujos de datos entre sus componentes. Un marco ampliamente utilizado con este fin es STRIDE, que clasifica las amenazas en seis categorías: suplantación de identidad (*Spoofing*), alteración de datos (*Tampering*), repudio (*Repudiation*), divulgación de información (*Information disclosure*), denegación de servicio (*Denial of service*) y elevación de privilegios (*Elevation of privilege*) [9]. En este trabajo, el modelado de amenazas se utiliza como insumo previo a las pruebas dinámicas, para orientar el esfuerzo de evaluación hacia los componentes y flujos de mayor riesgo.

Control de acceso en arquitecturas multiusuario

Maria.ag opera bajo un modelo en que múltiples empresas clientes comparten la misma instancia de la aplicación e infraestructura, cada una con sus propios datos y usuarios. Este tipo de arquitectura, conocida como *multiusuario* o *multi-tenant*, requiere que el control de acceso se aplique de forma consistente en cada operación del sistema y no únicamente a nivel de interfaz, de modo que un usuario autenticado solo pueda leer o modificar los recursos que le pertenecen [4].

Cuando esta verificación falla, se produce lo que OWASP clasifica como control de acceso roto, cuya manifestación más frecuente es la referencia directa insegura a objetos (*Insecure Direct Object Reference*, IDOR): un identificador de un recurso –por ejemplo, el de un sector de riego o un registro de riego manual– es manipulado por el usuario para acceder

a recursos que pertenecen a otra cuenta o empresa, sin que el servidor verifique la propiedad del recurso solicitado. Dado el modelo multiusuario de Maria.ag, este trabajo otorga especial relevancia a la verificación del control de acceso entre clientes y entre roles dentro de una misma cuenta.

Seguridad de interfaces de programación de aplicaciones (API)

Una parte sustancial de la funcionalidad de Maria.ag se sustenta en el intercambio de información con plataformas externas a través de API, tanto para la obtención de datos meteorológicos y de telemetría como para el envío de recomendaciones de riego hacia sistemas de terceros. Esta dependencia hace pertinente incorporar al marco de referencia de este trabajo los riesgos específicos de las API, los cuales no siempre son cubiertos en su totalidad por las guías orientadas a aplicaciones web tradicionales.

El OWASP API Security Top 10 [6] describe los riesgos más críticos en este tipo de interfaces, entre los que se cuentan la autorización rota a nivel de objeto, la asignación masiva de propiedades no esperadas en una petición, la exposición excesiva de datos en las respuestas, y la ausencia de límites de uso (*rate limiting*) que permitan contener el abuso de un endpoint. Adicionalmente, cuando una API actúa como intermediaria hacia un sistema externo, cobra relevancia el correcto manejo de las credenciales de dicha integración –su almacenamiento, rotación y alcance de permisos– así como la validación de los datos antes de reenviarlos, para evitar que un valor manipulado por el cliente sea transmitido sin control hacia la plataforma de destino.

Seguridad en sistemas con componentes ciberfísicos

A diferencia de una aplicación web convencional, Maria.ag forma parte de un sistema ciberfísico: sus recomendaciones y registros de riego son transmitidos a plataformas externas que gestionan equipamiento de riego en terreno (bombas, válvulas, controladores), por lo que una vulnerabilidad en el software puede manifestarse como un efecto físico sobre el cultivo o la infraestructura de riego, y no únicamente como una filtración o alteración de datos. Esta característica es análoga a la que se observa en los sistemas de control industrial y en el Internet de las Cosas (IoT) aplicado a la agricultura de precisión, donde la literatura ha documentado que errores de validación o fallas de autenticación en la capa de software pueden escalar a consecuencias operativas y económicas sobre el proceso físico que dicho

software supervisa o controla [10]. En este trabajo, esta consideración se traduce en un énfasis particular sobre la validación de los datos que viajan hacia las integraciones con capacidad de accionamiento, y sobre los mecanismos que evitan la duplicación o ejecución no intencionada de una orden de riego.

Hipótesis

La aplicación de un proceso sistemático de evaluación de seguridad, basado en la Guía de Pruebas de Seguridad Web de OWASP, el OWASP Top 10 y el sistema de puntuación CVSS, permite identificar y clasificar las vulnerabilidades de la plataforma Maria.ag –en particular las relacionadas con el aislamiento entre clientes, la autenticación y gestión de sesiones, la validación de datos y la seguridad de las integraciones con plataformas externas– y formular un plan de mitigación priorizado que, de aplicarse, abordaría los hallazgos de mayor severidad.

Preguntas de investigación

- ¿Cuáles son los componentes, activos, dependencias y superficies de ataque de la plataforma Maria.ag, y en cuáles de ellos se concentra el mayor riesgo, considerando el aislamiento entre clientes y las integraciones con capacidad de accionamiento sobre equipos de riego?
- ¿Qué vulnerabilidades y riesgos presenta la plataforma al ser evaluada según la metodología WSTG, y cómo se clasifican según el OWASP Top 10 y su severidad según CVSS?
- ¿Qué criterios (severidad, impacto sobre el proceso físico de riego y factibilidad de intervención) permiten priorizar las vulnerabilidades, y qué medidas de mitigación corresponde proponer para cada una?
- ¿Qué reducción del riesgo se estima que lograría la aplicación de las medidas propuestas, y qué tan factibles son según el equipo de desarrollo de Gota SpA?

Objetivo general

Evaluar la seguridad del software y de la arquitectura de la plataforma Maria.ag de la empresa Gota SpA, mediante la identificación y clasificación de sus vulnerabilidades y la formulación de un plan priorizado de medidas de mitigación, tomando como referencia la Guía de Pruebas de Seguridad Web de OWASP [3], el OWASP Top 10 [4] y el sistema de puntuación CVSS [5].

Objetivos específicos

1. Caracterizar la arquitectura, los componentes, las dependencias, los activos y los mecanismos de seguridad de la plataforma Maria.ag, mediante el modelo C4 y el levantamiento de información con el equipo de Gota SpA, para delimitar su superficie de ataque, con énfasis en el aislamiento entre clientes y en las integraciones con capacidad de accionamiento sobre equipos de riego.

2. Identificar y clasificar las vulnerabilidades y riesgos técnicos de la plataforma, mediante modelado de amenazas, análisis estático y dinámico, revisión de dependencias y evaluación de la arquitectura, utilizando como referencia la Guía de Pruebas de Seguridad Web de OWASP [3], el OWASP Top 10 [4], el OWASP API Security Top 10 [6] y el sistema de puntuación CVSS [5] para determinar la severidad.

3. Priorizar los hallazgos según su severidad, su impacto sobre los datos de los clientes y sobre el proceso físico de riego, y la factibilidad de intervención, y proponer medidas de mitigación específicas para cada uno.

4. Evaluar el plan de mitigación propuesto, estimando la reducción del riesgo mediante la recalificación CVSS de los hallazgos bajo el supuesto de que las medidas se apliquen, y validando su factibilidad con el equipo de desarrollo de Gota SpA.

Metodología

En este capítulo se describe el procedimiento seguido para evaluar la seguridad de Maria.ag y para formular el plan de mitigación que resulta de dicha evaluación. Se detallan el enfoque general del trabajo, su alcance, las condiciones de autorización y las consideraciones éticas, las fases que estructuran el trabajo y su correspondencia con los objetivos específicos, las herramientas empleadas, los criterios de clasificación y priorización de hallazgos, la forma en que se evalúa el plan de mitigación propuesto y, por último, las limitaciones del estudio.

Enfoque general

Este trabajo es de carácter aplicado y evaluativo. Consiste en una evaluación de seguridad de tipo *caja gris*: el evaluador cuenta con cuentas de usuario legítimas, con información de arquitectura entregada por la empresa y, en la medida en que Gota SpA lo autorice, con acceso de lectura al código fuente, lo que permite combinar pruebas dinámicas sobre la aplicación en ejecución con análisis estático del código y de sus dependencias.

El producto del trabajo es un informe de hallazgos clasificados y priorizados, acompañado de un plan de medidas de mitigación propuestas para cada uno. Las mitigaciones se *proponen* y se evalúan en términos de su factibilidad y de la reducción de riesgo que se estima lograrían, pero no se implementan sobre la plataforma; la implementación queda a cargo del equipo de desarrollo de Gota SpA y se plantea como trabajo futuro.

Alcance

El alcance de la evaluación se delimita a partir de la hipótesis de arquitectura presentada en el marco teórico y de las áreas de mayor riesgo identificadas en la introducción. Quedan dentro del alcance:

- la aplicación web y la API/backend de Maria.ag;
- la autenticación y la gestión de sesiones;
- el control de acceso, tanto entre empresas clientes como entre roles dentro de una misma cuenta;
- la validación de los datos ingresados por el usuario y de los datos transmitidos hacia las integraciones con capacidad de accionamiento;

- el manejo de las credenciales de las integraciones externas y los mecanismos que evitan la duplicación o ejecución no intencionada de una orden de riego;
- las dependencias de software y la configuración de los componentes de la plataforma.

Quedan fuera del alcance los sistemas de terceros (Agroclima, Dropcontrol, Talgil, Galcon y Hotjar/Microsoft Clarity), de los cuales solo se analiza la interacción que Maria.ag mantiene con ellos; los equipos de riego en terreno; las pruebas de ingeniería social; y las pruebas de denegación de servicio volumétrico.

Autorización, entorno de pruebas y consideraciones éticas

Dado que las pruebas de seguridad pueden afectar el funcionamiento de un sistema real, la evaluación se realiza bajo las siguientes condiciones:

- **Autorización escrita** de Gota SpA, que establece el alcance permitido y designa una persona de contacto técnica.
- **Entorno de pruebas** separado de producción y con datos ficticios. Cuando no sea posible contar con un ambiente de este tipo, las pruebas dinámicas se limitan a técnicas no destructivas y se coordinan previamente con la empresa.
- **Integraciones sin efecto físico**: las pruebas se ejecutan con credenciales de *sandbox* o con las integraciones deshabilitadas o simuladas, de modo que ninguna prueba pueda generar una orden de riego sobre equipos reales.
- **Confidencialidad**: la información y los accesos entregados se utilizan únicamente para los fines de este trabajo.
- **Divulgación responsable**: las vulnerabilidades críticas se comunican de inmediato al contacto técnico de la empresa, sin esperar la entrega del informe final.

Fases del trabajo

El trabajo se organiza en seis fases secuenciales, cada una asociada a uno de los objetivos específicos, como se resume en la Tabla 1.

En la fase de evaluación técnica, las pruebas dinámicas siguen las categorías de la WSTG [3], priorizando aquellas relacionadas con el alcance definido: gestión de la identidad y de la autenticación, autorización, gestión de sesiones, validación de entradas, lógica de negocio

Cuadro 1: Fases del trabajo y su relación con los objetivos específicos.

Fase	**OE**	**Actividades**	**Producto**
1. Caracterización	1	Levantamiento de información con Gota SpA; validación de los diagramas C4; identificación de activos, dependencias y mecanismos de seguridad existentes.	Arquitectura validada y superficie de ataque delimitada.
2. Modelado de amenazas	1–2	Análisis STRIDE sobre los componentes y flujos de datos de los diagramas C4, con énfasis en la API/backend y en las integraciones con accionamiento.	Catálogo de amenazas y lista de pruebas a ejecutar.
3. Evaluación técnica	2	Análisis estático del código, revisión de dependencias y pruebas dinámicas según las categorías de la WSTG, utilizando cuentas de al menos dos empresas clientes.	Hallazgos documentados con evidencia.
4. Clasificación	2	Asignación de categoría OWASP Top 10 (o API Security Top 10) y de puntaje CVSS a cada hallazgo.	Registro de hallazgos clasificados.
5. Priorización y propuesta	3	Aplicación de los criterios de priorización y formulación de una medida de mitigación para cada hallazgo priorizado.	Plan de mitigación priorizado.
6. Evaluación del plan	4	Validación de factibilidad con el equipo de Gota SpA y estimación del riesgo residual.	Indicadores de reducción de riesgo proyectada.

y pruebas sobre API. La verificación del aislamiento entre clientes se realiza con cuentas de dos empresas distintas, intentando acceder, desde cada una, a recursos pertenecientes a la otra mediante la manipulación de identificadores.

Herramientas

Las herramientas se seleccionarán según la tecnología efectivamente utilizada por la plataforma, que se confirma en la fase de caracterización. Se consideran, por categoría: un proxy de interceptación y escáner de aplicaciones web para las pruebas dinámicas (como OWASP ZAP o Burp Suite Community); una herramienta de análisis estático de código (como Semgrep); una herramienta de análisis de composición de software para revisar dependencias con vulnerabilidades conocidas; y una herramienta de detección de secretos expuestos en el repositorio. Los resultados automáticos se validan manualmente para descartar falsos positivos, y las pruebas de control de acceso entre clientes y de lógica de negocio se realizan de forma manual, ya que las herramientas automáticas no las cubren adecuadamente.

Clasificación de hallazgos

Cada hallazgo se registra con su descripción, el componente afectado, los pasos para reproducirlo, la evidencia y el impacto sobre la confidencialidad, integridad y disponibilidad. Posteriormente se clasifica según:

- la **categoría de riesgo** del OWASP Top 10 [4] o, si corresponde a una API, del OWASP API Security Top 10 [6];
- la **severidad**, mediante el puntaje base de CVSS v4.0 [5], que se agrupa en los niveles bajo (0,1–3,9), medio (4,0–6,9), alto (7,0–8,9) y crítico (9,0–10,0). Cuando el contexto de Maria.ag lo justifica, se ajusta el puntaje mediante las métricas de entorno, por ejemplo ante un hallazgo que pueda traducirse en una orden de riego no deseada.

Criterios de priorización

Dado que no es posible proponer mitigaciones con el mismo nivel de detalle para todos los hallazgos dentro del tiempo disponible, estos se priorizan con los criterios de la Tabla 2.

Con ellos se definen tres niveles de prioridad. Es de **prioridad alta** todo hallazgo con severidad alta o crítica, o que afecte el aislamiento entre clientes o el accionamiento de

Cuadro 2: Criterios de priorización de hallazgos.

Criterio	Descripción	Uso
Severidad	Puntaje CVSS del hallazgo.	Determina el nivel de prioridad.
Impacto sobre el negocio y el proceso físico	Si el hallazgo permite acceso entre empresas clientes o el envío no autorizado de órdenes de riego hacia las integraciones.	Eleva el hallazgo a prioridad alta, independientemente de su puntaje.
Factibilidad de intervención	Esfuerzo estimado de la corrección y riesgo de afectar funcionalidades existentes (alta, media o baja).	Ordena los hallazgos dentro de un mismo nivel de prioridad.

equipos de riego; de **prioridad media**, el de severidad media que no presente esos impactos; y de **prioridad baja**, el de severidad baja. Dentro de cada nivel se atienden primero los de mayor factibilidad de intervención, de modo de obtener la mayor reducción de riesgo con el menor esfuerzo.

Evaluación del plan de mitigación

Para cada hallazgo priorizado se propone una medida de mitigación que describe la corrección sugerida, el componente sobre el que se aplicaría y una estimación del esfuerzo. Como las medidas no se implementan, su evaluación se basa en dos mecanismos:

1. **Validación de factibilidad con el equipo de Gota SpA.** Las propuestas se presentan al equipo de desarrollo, que valora su factibilidad técnica, el esfuerzo requerido y el riesgo de afectar funcionalidades existentes. De ese análisis se identifican, además, las funcionalidades que deberían cubrirse con pruebas de regresión al momento de implementar cada medida.

2. **Estimación del riesgo residual.** Cada hallazgo se vuelve a puntuar con CVSS bajo el supuesto de que la mitigación se aplica correctamente, modificando las métricas que la medida alteraría. El resultado es una *proyección* de la reducción de riesgo y no una medición.

Con esta información se construyen los indicadores de la Tabla 3, que permiten comparar el estado actual de la plataforma con el estado proyectado.

Cuadro 3: Indicadores para evaluar el plan de mitigación.

Indicador	**Descripción**
Hallazgos por severidad	Cantidad de hallazgos en cada nivel, en el estado actual y en el estado proyectado.
Puntaje CVSS	Puntaje de cada hallazgo priorizado, actual y proyectado, y su reducción.
Cobertura del plan	Proporción de los hallazgos de prioridad alta que cuentan con una medida de mitigación propuesta.
Factibilidad validada	Proporción de las medidas propuestas que el equipo de Gota SpA considera factibles de implementar.

Limitaciones

Los resultados de este trabajo deben interpretarse considerando las siguientes limitaciones:

- La efectividad de las mitigaciones se estima, no se mide: al no implementarse, no es posible repetir las pruebas ni ejecutar pruebas de regresión.
- La evaluación corresponde a un momento puntual y a un tiempo acotado; no garantiza la ausencia de vulnerabilidades no detectadas.
- El entorno de pruebas puede diferir de producción en su configuración y en sus datos.
- La arquitectura se basa en información pública y en la recabada durante la pasantía, validada parcialmente con la empresa.
- No se evalúan los sistemas de terceros ni las vulnerabilidades asociadas a la ingeniería social.

Referencias

[1] Gota SpA. «Gestión y operación tecnológica del agua,» visitado 28 de sep. de 2026. dirección: https://gota.ag/

[2] Gota SpA. «MARIA: Modelo Automatizado de Riego con Inteligencia Artificial,» visitado 28 de sep. de 2026. dirección: https://maria.ag/

[3] OWASP Foundation. «Web Security Testing Guide,» visitado 28 de sep. de 2026. dirección: https://owasp.org/www-project-web-security-testing-guide/

[4] OWASP Foundation. «OWASP Top 10:2025,» visitado 28 de sep. de 2026. dirección: https://owasp.org/Top10/2025

[5] FIRST.Org, Inc. «Common Vulnerability Scoring System Version 4.0: Specification Document,» visitado 28 de sep. de 2026. dirección: https://www.first.org/cvss/v4-0/specification-document

[6] OWASP Foundation. «OWASP API Security Top 10:2023,» visitado 20 de oct. de 2026. dirección: https://owasp.org/API-Security/editions/2023/en/0x00-header/

[7] W. Stallings y L. Brown, *Computer Security: Principles and Practice*, 4th. Harlow: Pearson, 2018.

[8] S. Brown. «The C4 Model for Visualising Software Architecture,» visitado 8 de oct. de 2026. dirección: https://c4model.com/

[9] A. Shostack, *Threat Modeling: Designing for Security*. Indianapolis, IN: Wiley, 2014.

[10] C. Fathy y H. M. Ali, «A Secure IoT-Based Irrigation System for Precision Agriculture Using the Expeditious Cipher,» *Sensors*, vol. 23, n.º 4, pág. 2091, 2023. DOI: 10.3390/s23042091